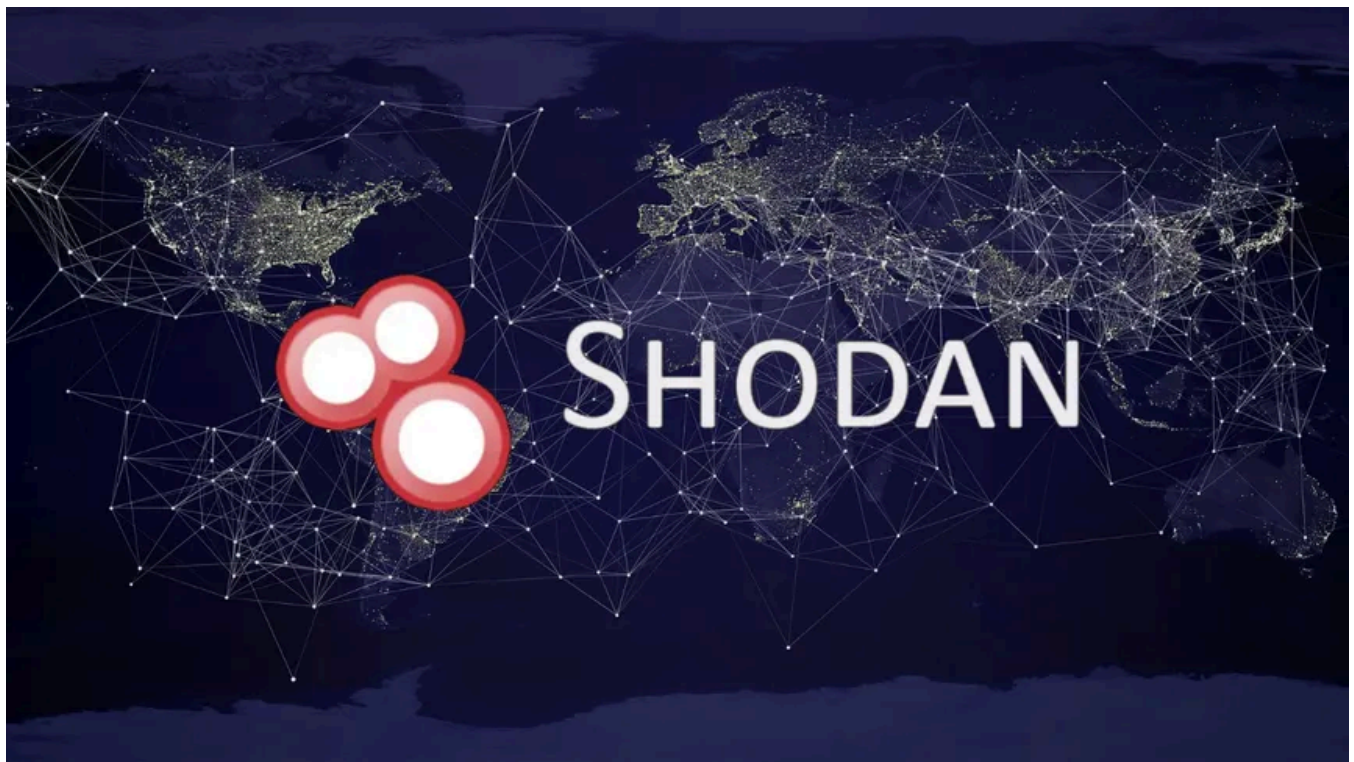


Manual Completo de Shodan



[!warning] AVISO LEGAL Este manual ha sido creado exclusivamente con fines educativos y de investigación en seguridad. El uso de Shodan o cualquier herramienta de búsqueda y recopilación de información debe realizarse de forma ética y legal.

Descargo de responsabilidad: El autor de este manual no se hace responsable del mal uso que pueda hacerse de la información aquí contenida. El usuario es el único responsable de sus acciones y debe asegurarse de cumplir con todas las leyes y regulaciones aplicables en su jurisdicción. El escaneo no autorizado de sistemas, intentos de intrusión o cualquier actividad similar pueden constituir un delito en muchos países.

Todas las actividades realizadas con la información proporcionada en este manual deben:

- Contar con el consentimiento explícito del propietario del sistema
- Cumplir con las leyes locales, nacionales e internacionales
- Respetar la privacidad y seguridad de terceros
- Ser reportadas responsablemente a las partes afectadas si se descubren vulnerabilidades

El uso indebido de estas técnicas podría resultar en sanciones civiles y/o penales.

¿Qué es Shodan?

Shodan es un motor de búsqueda especializado en dispositivos conectados a Internet, incluyendo servidores, routers, cámaras, sistemas industriales y dispositivos IoT. A diferencia de los motores de búsqueda tradicionales que indexan contenido web, Shodan escanea puertos, recopila banners y metadatos de servicios en Internet, permitiendo a los usuarios encontrar dispositivos específicos, servicios vulnerables y sistemas expuestos.

Empezando con Shodan

Configuración inicial

- Regístrate en <https://www.shodan.io/> (hay funciones limitadas con cuenta gratuita)
- Explora la interfaz web o considera adquirir una suscripción para acceso completo
- Las cuentas de pago ofrecen más resultados, filtros avanzados y acceso a la API

Interfaz web básica

- Usa la barra de búsqueda para consultas utilizando la sintaxis de Shodan
- Filtra resultados por país, puerto, sistema operativo, entre otros
- Exporta resultados en diferentes formatos (JSON, CSV, etc.)

Guía de Sintaxis: Dorks de Shodan

1. Búsqueda por servicio/protocolo

http	→ Todos los dispositivos HTTP expuestos
https	→ Todos los dispositivos HTTPS expuestos
ftp	→ Servidores FTP expuestos
ssh	→ Servicios SSH accesibles
telnet	→ Dispositivos con Telnet habilitado (muy inseguro)
rdp	→ Servicios de Escritorio Remoto de Windows
vnc	→ Servicios VNC (Virtual Network Computing)
smtp	→ Servidores de correo SMTP
snmp	→ Dispositivos con SNMP expuesto
dns	→ Servidores DNS
ntp	→ Servidores de tiempo NTP
ssl	→ Servicios con SSL/TLS
modbus	→ Sistemas de control industrial usando Modbus
s7	→ PLCs Siemens usando protocolo S7
bacnet	→ Sistemas de automatización de edificios
mqtt	→ Broker MQTT para IoT
coap	→ Protocolo IoT Constrained Application Protocol
rtsp	→ Cámaras y dispositivos con streaming RTSP
sip	→ Telefonía IP usando protocolo SIP
imap	→ Servidores de correo IMAP
pop3	→ Servidores de correo POP3

2. Búsqueda por puerto

port:80	→ Dispositivos con puerto 80 abierto (HTTP)
port:443	→ Dispositivos con puerto 443 abierto (HTTPS)
port:22	→ Dispositivos con puerto 22 abierto (SSH)
port:23	→ Dispositivos con puerto 23 abierto (Telnet)
port:21	→ Dispositivos con puerto 21 abierto (FTP)
port:3389	→ Dispositivos con puerto 3389 abierto (RDP)
port:8080	→ Dispositivos con puerto alternativo HTTP

port:8443	→ Dispositivos con puerto alternativo HTTPS
port:3306	→ Bases de datos MySQL expuestas
port:5432	→ Bases de datos PostgreSQL expuestas
port:27017	→ Bases de datos MongoDB expuestas
port:9200	→ Instancias Elasticsearch expuestas
port:6379	→ Servidores Redis expuestos
port:11211	→ Instancias Memcached expuestas
port:5900	→ Servidores VNC
port:161	→ Servicios SNMP
port:25	→ Servicios SMTP
port:445	→ Servicios SMB/CIFS (Windows)
port:1433	→ Bases de datos SQL Server
port:1521	→ Bases de datos Oracle

3. Dispositivos IoT y Cámaras

webcam	→ Webcams genéricas
webcamxp	→ Cámaras usando WebcamXP
"camera model"	→ Búsqueda por modelo específico de cámara
title:"netcam"	→ Cámaras con "netcam" en el título
"Server: SQ-WEBCAM"	→ Tipo específico de servidor de cámara
title:"axis"	→ Cámaras Axis
title:"hikvision"	→ Cámaras Hikvision
title:"dahua"	→ Cámaras Dahua
title:"yawcam"	→ Cámaras Yawcam
title:"blueiris"	→ Software Blue Iris para cámaras
title:"avtech"	→ Cámaras Avtech
has_screenshot:true	→ Dispositivos con capturas de pantalla disponibles
"NETSurveillance"	→ Software común en cámaras chinas
"WVC80N"	→ Cámaras Linksys WVC80N
"D-Link Internet Camera"	→ Cámaras D-Link
"MOBOTIX"	→ Cámaras MOBOTIX
"Hipcam"	→ Cámaras Hipcam
"IPCamera_Logo"	→ Cámaras genéricas con logo
"ipcam"	→ Término genérico para cámaras IP
"rtsp://"	→ Cámaras con streams RTSP expuestos

4. Sistemas industriales y SCADA

tag:ics	→ Sistemas de control industrial
tag:scada	→ Sistemas SCADA
port:502	→ Puerto Modbus (sistemas industriales)
port:102	→ Puerto S7 (Siemens)
port:47808	→ Puerto BACnet (automatización de edificios)
port:1911	→ Puerto Niagara Fox
port:20000	→ Puerto de servidores DNP3
"Schneider Electric"	→ Dispositivos de Schneider Electric
"Siemens"	→ Dispositivos de Siemens
"Allen-Bradley"	→ Dispositivos Allen-Bradley (Rockwell)
"Honeywell"	→ Sistemas Honeywell
"Mitsubishi Electric"	→ Dispositivos Mitsubishi

"Omron"	→ Dispositivos Omron
"Rockwell Automation"	→ Rockwell Automation
"PLC"	→ Controladores lógicos programables
"HMI"	→ Interfaces hombre-máquina
"RTU"	→ Unidades terminales remotas
"HVAC"	→ Sistemas de climatización
"BMS"	→ Sistemas de gestión de edificios
"water plant"	→ Plantas de tratamiento de agua
"energy management"	→ Sistemas de gestión energética

5. Vulnerabilidades y sistemas expuestos

vuln:	→ Búsqueda por CVE específica (ej: vuln:CVE-2021-44228)
"default password"	→ Dispositivos con contraseñas predeterminadas
ssl:	→ Vulnerabilidades SSL específicas
"X-Jenkins"	→ Servidores Jenkins expuestos
"X-Drupal"	→ Sitios Drupal
"wp-login"	→ Páginas de login de WordPress
"phpmyadmin"	→ Instalaciones phpMyAdmin
apache	→ Servidores Apache
nginx	→ Servidores Nginx
iis	→ Servidores Microsoft IIS
title:"dashboard"	→ Paneles de control
title:"admin"	→ Paneles de administración
"phpinfo()"	→ Páginas phpinfo expuestas
"Index of /"	→ Listados de directorios
"error"	→ Páginas con errores
html:"control panel"	→ Paneles de control
http.title:"login"	→ Páginas de inicio de sesión
http.component:jquery	→ Sitios que utilizan jQuery
http.component:bootstrap	→ Sitios que utilizan Bootstrap
http.component:php	→ Sitios que utilizan PHP
http.component:wordpress	→ Sitios WordPress
http.component:drupal	→ Sitios Drupal

6. Búsqueda por país y organización

country:US	→ Dispositivos en Estados Unidos
country:ES	→ Dispositivos en España
country:CN	→ Dispositivos en China
country:JP	→ Dispositivos en Japón
country:BR	→ Dispositivos en Brasil
country:RU	→ Dispositivos en Rusia
country:DE	→ Dispositivos en Alemania
country:FR	→ Dispositivos en Francia
country:UK	→ Dispositivos en Reino Unido
city:"New York"	→ Dispositivos en Nueva York
city:"London"	→ Dispositivos en Londres
city:"Tokyo"	→ Dispositivos en Tokio
city:"Barcelona"	→ Dispositivos en Barcelona
org:"Amazon"	→ Dispositivos de Amazon

org:"Microsoft"	→ Dispositivos de Microsoft
org:"Google"	→ Dispositivos de Google
org:"Cisco"	→ Dispositivos de Cisco
org:"AT&T"	→ Dispositivos de AT&T
org:"Comcast"	→ Dispositivos de Comcast
org:"Cloudflare"	→ Dispositivos de Cloudflare
org:"OVH"	→ Dispositivos de OVH
net:"192.168.1.0/24"	→ Búsqueda por rango de red (CIDR)
asn:	→ Búsqueda por ASN (ej: asn:AS15169 para Google)

7. Búsqueda por tecnologías específicas

os:windows	→ Sistemas Windows
os:linux	→ Sistemas Linux
os:android	→ Dispositivos Android
os:ios	→ Dispositivos iOS
os:"Windows Server 2016"	→ Versión específica de Windows
os:"Ubuntu"	→ Sistemas Ubuntu
os:"Debian"	→ Sistemas Debian
os:"CentOS"	→ Sistemas CentOS
product:Apache	→ Servidores Apache
product:nginx	→ Servidores Nginx
product:IIS	→ Servidores IIS
product:MySQL	→ Bases de datos MySQL
product:MongoDB	→ Bases de datos MongoDB
product:Elasticsearch	→ Instancias Elasticsearch
product:OpenSSH	→ Servicios OpenSSH
product:Exim	→ Servidores de correo Exim
product:Postfix	→ Servidores de correo Postfix
product:Grafana	→ Instancias Grafana
product:Jenkins	→ Servidores Jenkins
product:Kubernetes	→ Clusters Kubernetes
product:Docker	→ Hosts Docker

8. Búsqueda por certificados SSL/TLS

ssl.cert.subject.cn:example.com	→ Certificados con ese Common Name
ssl.cert.issuer.cn:"Let's Encrypt"	→ Certificados emitidos por Let's Encrypt
ssl.cert.issuer.cn:"DigiCert"	→ Certificados emitidos por DigiCert
ssl.cert.issuer.cn:"Comodo"	→ Certificados emitidos por Comodo
ssl.cert.issuer.cn:"GoDaddy"	→ Certificados emitidos por GoDaddy
ssl.cert.expired:true	→ Certificados expirados
ssl.cert.self_signed:true	→ Certificados autofirmados
ssl:	→ Buscar vulnerabilidades SSL (ej: ssl:heartbleed)
has_ssl:true	→ Servicios con SSL habilitado
ssl.cert.fingerprint:	→ Búsqueda por huella digital del certificado
ssl.cert.serial:	→ Búsqueda por número de serie del certificado
ssl.cert.pubkey.bits:2048	→ Certificados con claves de 2048 bits
ssl.cert.pubkey.type:rsa	→ Certificados con claves RSA
ssl.version:"TLSv1.2"	→ Servicios usando TLS 1.2

9. Búsqueda por información específica del dispositivo

hostname:	→ Búsqueda por nombre de host (ej: hostname:example.com)
server:	→ Búsqueda por tipo de servidor (ej: server:Apache)
title:	→ Búsqueda por título HTTP (ej: title:"Login Page")
html:	→ Búsqueda en contenido HTML (ej: html:"password")
product:	→ Búsqueda por producto (ej: product:nginx)
version:	→ Búsqueda por versión (ej: nginx version:1.18.0)
geo:	→ Búsqueda por coordenadas (ej: geo:"37.7, -122.4")
before:01/01/2022	→ Resultados antes de una fecha
after:01/01/2021	→ Resultados después de una fecha
favicon:	→ Búsqueda por hash de favicon
http.status:200	→ Páginas con código de estado 200
http.status:404	→ Páginas con código de estado 404
http.status:500	→ Páginas con código de estado 500
http.status:401	→ Páginas que requieren autenticación
http.status:403	→ Páginas prohibidas
http.component:	→ Búsqueda por componente HTTP

10. Búsqueda por contenido específico

"default password"	→ Páginas con texto "default password"
"admin password"	→ Páginas con texto "admin password"
"private key"	→ Posibles claves privadas expuestas
"password" html:"input"	→ Formularios de contraseña
"config" html:"database"	→ Posibles configuraciones de base de datos
"error database connection"	→ Errores de conexión a bases de datos
"Access denied"	→ Mensajes de acceso denegado
"SQL syntax"	→ Errores de sintaxis SQL visibles
"exception"	→ Páginas con excepciones no capturadas
"stack trace"	→ Páginas con trazas de pila
"API key"	→ Posibles claves API expuestas
"Auth" "Token"	→ Tokens de autenticación
"Internal Server Error"	→ Errores de servidor internos
"admin" port:8080	→ Posibles paneles de administración en puerto 8080
title:"Index of" "Parent Directory"	→ Listados de directorios
"XAMPP" "phpinfo"	→ Instalaciones XAMPP con phpinfo
title:"Login" "Administrator"	→ Páginas de login administrativas

Ejemplos de Búsquedas Avanzadas

1. Búsqueda de Windows Server con RDP Expuesto

```
# Búsqueda básica de servicios RDP
port:3389 "Remote Desktop Protocol"

# Servicios RDP en versiones específicas de Windows Server
port:3389 os:"Windows Server 2012 R2"
port:3389 os:"Windows Server 2008 R2"
port:3389 os:"Windows Server 2003"
```

```
# Servicios RDP en Chile (u otro país específico)
port:3389 country:CL "Windows Server"

# Versiones antiguas de Windows Server (anteriores a 2016) con RDP expuesto
port:3389 "Windows Server" -"2016" -"2019" -"2022"

# Servicios RDP con capturas de pantalla disponibles
port:3389 has_screenshot:true "Windows Server"

# RDP expuesto con autenticación NLA desactivada (muy inseguro)
"requires-authentication:false" port:3389

# Búsqueda de RDP vulnerables a BlueKeep (CVE-2019-0708)
has_vuln:CVE-2019-0708 port:3389

# Búsqueda combinada por organización y RDP
org:"Nombre de la Organización" port:3389

# RDP en puertos no estándar
"Remote Desktop Protocol" -port:3389

# Búsqueda específica de servicios Terminal Server
"Terminal Services" port:3389
```

2. Búsqueda de Servidores SSH Expuestos

```
# Búsqueda básica de servicios SSH
port:22 ssh

# SSH en versiones específicas de OpenSSH
product:"OpenSSH" version:"7.4p1"
product:"OpenSSH" version:"8.2p1"

# Búsqueda por país (ejemplo: Brasil)
port:22 country:BR product:"OpenSSH"

# Versiones antiguas de OpenSSH (potencialmente vulnerables)
port:22 product:"OpenSSH" -version:"8" -version:"9"

# SSH en sistemas Linux específicos
port:22 os:"Ubuntu" country:DE

# Buscar SSH con autenticación por contraseña (no solo clave)
port:22 "password"

# SSH en servidores específicos
port:22 product:"OpenSSH" os:"Debian"

# SSH configurado en puertos no estándar
product:"OpenSSH" -port:22
```

```
# Búsqueda de SSH en redes corporativas
port:22 org:"Google"

# SSH con problemas de configuración
port:"22" "bad protocol version identification"
```

3. Búsqueda de Bases de Datos Expuestas

```
# MySQL sin autenticación (muy peligroso)
port:3306 product:"MySQL" -authentication

# Redis expuesto sin autenticación
port:6379 product:"Redis"

# MongoDB sin autenticación (Francia)
product:"MongoDB" port:27017 -authentication country:FR

# Elasticsearch expuesto (Italia)
port:9200 product:"Elasticsearch" country:IT

# PostgreSQL con contraseñas débiles
product:"PostgreSQL DB" port:5432 "password"

# Microsoft SQL Server expuesto
product:"Microsoft SQL Server" port:1433

# CouchDB expuesto (Reino Unido)
product:"CouchDB" port:5984 country:UK

# Cassandra sin autenticación
product:"Cassandra DB" port:9042 country:NL

# Oracle DB expuesta
product:"Oracle DB" port:1521

# Firebase expuesto
"Firebase" "apiKey"
```

4. Búsqueda de Sistemas de Control Industrial

```
# Sistemas SCADA en Estados Unidos
tag:scada country:US

# Modbus en plantas industriales
port:502 product:modbus

# Dispositivos Siemens en Alemania
"Siemens" country:DE port:102

# Dispositivos industriales Allen-Bradley
"PLC" "Allen-Bradley" port:44818
```



```
# Servidores Niagara Fox (sistemas de edificios)
"Niagara Web Server" port:1911

# Dispositivos BACnet (automatización de edificios)
product:"BACnet" port:47808 country:FR

# Sistemas Rockwell Automation
"Rockwell Automation" port:1962

# Sistemas de gestión energética en Japón
"energy management system" country:JP

# Plantas de tratamiento de agua
"water treatment" tag:ics country:US

# Paneles de control HMI expuestos
"HMI" "Login" has_screenshot:true
```

5. Búsqueda de Cámaras de Vigilancia

```
# Cámaras Hikvision en China
title:"hikvision" country:CN has_screenshot:true

# Cámaras Axis en Europa
title:"axis" (country:DE OR country:FR OR country:IT) has_screenshot:true

# Cámaras Dahua expuestas
product:"Dahua" port:80 has_screenshot:true

# Cámaras con streams RTSP expuestos
"rtsp://" has_screenshot:true

# Cámaras en Brasil con accesos no protegidos
webcam country:BR "basic realm"

# Yawcam en España
"Server: yawcam" country:ES

# Cámaras con flujos públicos accesibles
webcam "stream" has_screenshot:true

# Sistemas de vigilancia DVR
"DVR Login" has_screenshot:true

# Cámaras IP genéricas
"ipcam" has_screenshot:true country:MX

# Sistemas de vigilancia profesionales
"surveillance" "login" has_screenshot:true
```

Caso Práctico: Auditoría de Seguridad RDP

1. Inventario de servidores RDP expuestos:

```
port:3389 net:"192.168.0.0/16" "Windows Server"
```

2. Identificación de servidores RDP vulnerables:

```
port:3389 "Windows Server 2008" has_vuln:true
```

3. Verificación de configuraciones inseguras:

```
port:3389 "Windows Server" "requires-authentication:false"
```

4. Monitorización continua con Shodan Monitor:

- Configura alertas para nuevos servidores RDP detectados en tu rango de IP
- Configura notificaciones para nuevas vulnerabilidades en servicios RDP

5. Ejemplo de correlación con otras herramientas:

```
# Script Python para extraer IPs de servidores RDP vulnerables y escanearlos con Nmap
import shodan
import os
import subprocess

# Configurar API key
SHODAN_API_KEY = os.environ.get("SHODAN_API_KEY")
api = shodan.Shodan(SHODAN_API_KEY)

# Búsqueda de servidores RDP vulnerables
results = api.search('port:3389 os:"Windows Server 2008" country:CL')

# Procesar resultados
for result in results['matches']:
    ip = result['ip_str']
    print(f"Encontrado servidor RDP vulnerable: {ip}")

# Opcional: escanear con Nmap
nmap_cmd = f"nmap -Pn -sV -p 3389 {ip}"
subprocess.run(nmap_cmd, shell=True)
```

Caso Práctico: Auditoría de SSH

1. Inventario de servidores SSH expuestos:

```
port:22 net:"10.0.0.0/8" product:"OpenSSH"
```

2. Identificación de versiones de SSH vulnerables:

```
port:22 product:"OpenSSH" version:"5.3" country:DE
```

3. Búsqueda específica por CVE en SSH:

```
port:22 vuln:CVE-2018-15473
```

4. Monitorización de configuraciones SSH:

```
# Script Python para verificar versiones de SSH en una lista de IPs
import shodan
import csv
import os

# Configurar API key
SHODAN_API_KEY = os.environ.get("SHODAN_API_KEY")
api = shodan.Shodan(SHODAN_API_KEY)

# Abrir archivo para guardar resultados
with open('ssh_audit.csv', 'w', newline='') as csvfile:
    fieldnames = ['IP', 'Version', 'Country', 'Organization', 'Last Update']
    writer = csv.DictWriter(csvfile, fieldnames=fieldnames)
    writer.writeheader()

# Búsqueda de servidores SSH
results = api.search('port:22 product:"OpenSSH" org:"MiOrganizacion"')

# Procesar resultados
for result in results['matches']:
    writer.writerow({
        'IP': result['ip_str'],
        'Version': result.get('product', '') + ' ' + result.get('version', ''),
        'Country': result.get('location', {}).get('country_name', ''),
        'Organization': result.get('org', ''),
        'Last Update': result.get('timestamp', '')
    })
```

Técnicas Avanzadas de Búsqueda

Operadores Booleanos

Shodan soporta operadores booleanos para crear consultas complejas:

keyword1 keyword2	→ AND implícito (ambas palabras clave deben estar presentes)
keyword1 OR keyword2	→ OR (al menos una palabra clave debe estar presente)
keyword1 -keyword2	→ NOT (excluye resultados con la segunda palabra clave)
"exact phrase"	→ Búsqueda exacta de frases
()	→ Agrupación de términos para control de precedencia

Ejemplos de uso:

nginx country:US -port:443 → Nginx en EE.UU. que NO usan puerto 443
(webcam OR camera) has_screenshot:true → Webcams o cámaras con capturas de pantalla
"admin panel" -401 -403 → Paneles de administración sin autenticación o acceso denegado

Filtros especiales

has_screenshot:true → Resultados con capturas de pantalla disponibles
screenshot.label:webcam → Capturas etiquetadas como webcam
has_vuln:CVE-2021-44228 → Dispositivos vulnerables a Log4Shell
has_ssl:true → Dispositivos con SSL habilitado
has_ipv6:true → Dispositivos con IPv6
device:router → Filtrado por tipo de dispositivo
cloud.provider:AWS → Dispositivos en la nube de AWS
cloud.provider:Azure → Dispositivos en Microsoft Azure
cloud.provider:GCP → Dispositivos en Google Cloud
cloud.service: → Filtro por servicio en la nube específico
honeypot:true → Identificar honeypots (trampas)

APIs y Herramientas de Shodan

Shodan ofrece varias APIs y herramientas CLI para automatizar búsquedas y análisis:

```
# Instalación de la CLI de Shodan
pip install shodan

# Configuración de la clave API
shodan init TU_API_KEY

# Búsquedas básicas
shodan search apache

# Información sobre un host específico
shodan host 8.8.8.8

# Escanear tu propio host
shodan scan submit 1.2.3.4

# Estadísticas sobre un término de búsqueda
shodan stats apache country

# Descargar resultados en formato JSON
shodan download resultados_apache apache

# Convertir resultados a otros formatos
shodan convert resultados_apache.json.gz csv
```

Shodan Monitor y Alertas

Shodan Monitor permite configurar alertas para monitorear tu infraestructura:

- **Configuración:** En <https://monitor.shodan.io/>
- Funcionalidades
 - :
 - Monitoreo de rangos de IP específicos
 - Alertas por nuevos puertos o servicios
 - Notificaciones por vulnerabilidades
 - Detección de cambios en servicios

Comparación: Shodan vs Otras Herramientas OSINT

Herramienta	Enfoque principal	Puntos fuertes
Shodan	Dispositivos conectados a Internet, sistemas industriales	Amplia cobertura, enfoque en SCADA/ICS, datos históricos, integraciones
FOFA	Dispositivos IoT, servicios web, amplia base de datos asiática	Alta precisión en Asia, buena granularidad en consultas
Censys	Certificados SSL/TLS, análisis profundo de infraestructura	Excelente para análisis de certificados, buena indexación histórica
ZoomEye	Dispositivos IoT y servicios específicos	Similar a FOFA, buen complemento para verificar resultados
BinaryEdge	Escaneo completo de Internet, datos estructurados	Excelente para análisis avanzados, buena API

Consideraciones Éticas y de Seguridad

 Importante:

- Usa Shodan de manera ética. Muchos resultados pueden ser sistemas vulnerables o expuestos sin autorización.
- Respeta los límites de la API (Shodan tiene restricciones en planes gratuitos).
- Protege tu API Key (no la compartas en scripts públicos).
- Usa la información obtenida solo para fines educativos o con el consentimiento adecuado.
- Obtén permisos adecuados antes de realizar pruebas en sistemas descubiertos.
- El escaneo no autorizado puede ser ilegal en muchas jurisdicciones.
- Las consultas continuas y agresivas pueden ser interpretadas como un ataque o reconocimiento malicioso.
- Considera el aspecto legal: las leyes de ciberseguridad varían según el país.

Casos de Uso de Shodan en Ciberseguridad

Evaluación de superficie de ataque

- Identificar dispositivos y servicios expuestos de tu organización
- Detectar servidores no autorizados o shadow IT
- Verificar la implementación correcta de políticas de seguridad
- Monitorear IPs públicas usando Shodan Monitor

Investigación de vulnerabilidades

- Buscar dispositivos afectados por CVEs específicas
- Identificar versiones de software vulnerable en Internet
- Investigar el impacto global de nuevas vulnerabilidades
- Verificar la exposición de sistemas críticos

Inteligencia sobre amenazas

- Investigar infraestructura relacionada con actores maliciosos
- Identificar patrones en servicios comprometidos
- Reconocer servidores C&C a través de características específicas
- Monitorear actividad inusual en rangos de IP

Servicios adicionales de Shodan

Shodan Maps

Visualización geográfica de resultados de búsqueda <https://maps.shodan.io/>

Shodan Images

Exploración de capturas de pantalla de dispositivos <https://images.shodan.io/>

Shodan Exploits

Base de datos de exploits y vulnerabilidades <https://exploits.shodan.io/>

Shodan Radar

Visualización de datos de dispositivos conectados <https://radar.shodan.io/>

[!tip] Consejo Para proteger tus credenciales de API, considera almacenarlas en un archivo de configuración seguro o como variables de entorno:

```
export SHODAN_API_KEY="tu_api_key"
```

Luego accede a ellas en tu script con:

```
import os
api_key = os.environ.get("SHODAN_API_KEY")
```

[!warning] Advertencia Algunos de estos dorks pueden revelar sistemas vulnerables. Utiliza esta información solo para proteger tus propios sistemas o en entornos con autorización explícita.

[!info] Compatibilidad con otras herramientas Shodan se integra con múltiples herramientas de seguridad como Maltego, Metasploit, y Nmap. También puedes usar la API con Python, Golang o cualquier lenguaje que soporte HTTPS.